🌐 Module 05: Web Application Penetration Testing

```
# Exercise 15: Performing a CSRF Attack
```

Scenario

Cross-Site Request Forgery (CSRF) is an attack that forces an end user to execute unwanted actions on a web application in which they are currently authenticated. With a little help from social engineering (such as sending a link via email or chat), an attacker may trick the users of a web application into executing actions of the attacker's choosing (e.g., transferring funds, changing email addresses, or updating passwords).

If the victim is an ordinary user, a successful CSRF attack can compromise state-changing requests like transferring funds. If the victim is an administrative account, CSRF can compromise the entire web application.

In this exercise, we simulate a CSRF attack on the **bWAPP** web application (`Cross-Site Request Forgery (Transfer Amount)` module) to deduct funds automatically from a victim's active session.

Objective

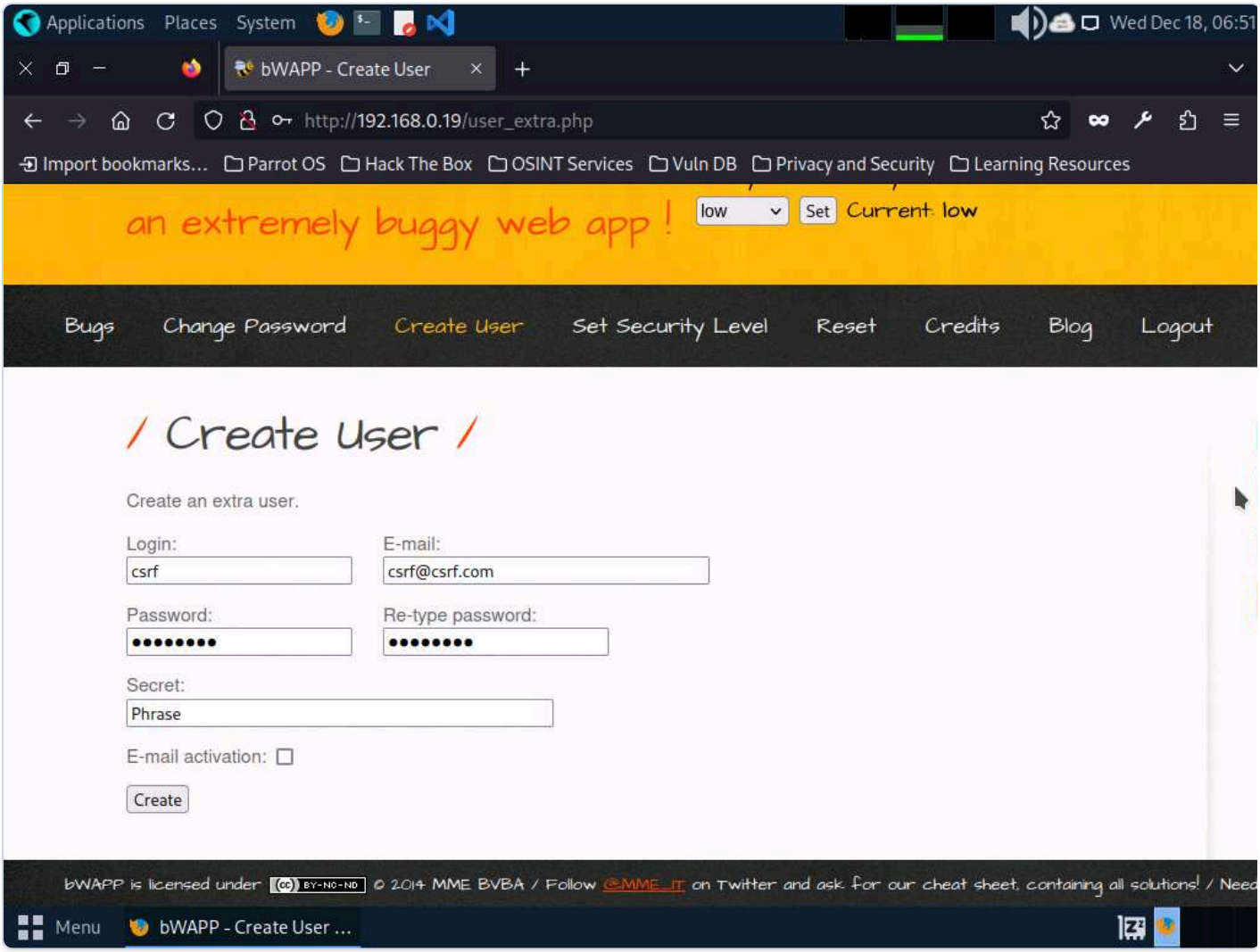
The objective of this lab is to help students learn how to:
- Understand the mechanics of session trust exploitation in web applications
- Construct custom HTML CSRF exploit pages targeting unauthenticated state-changing HTTP requests
- Execute unauthorized fund transfers (500 EUR deduction) against an active user session in bWAPP

Task 1: Performing a CSRF Attack

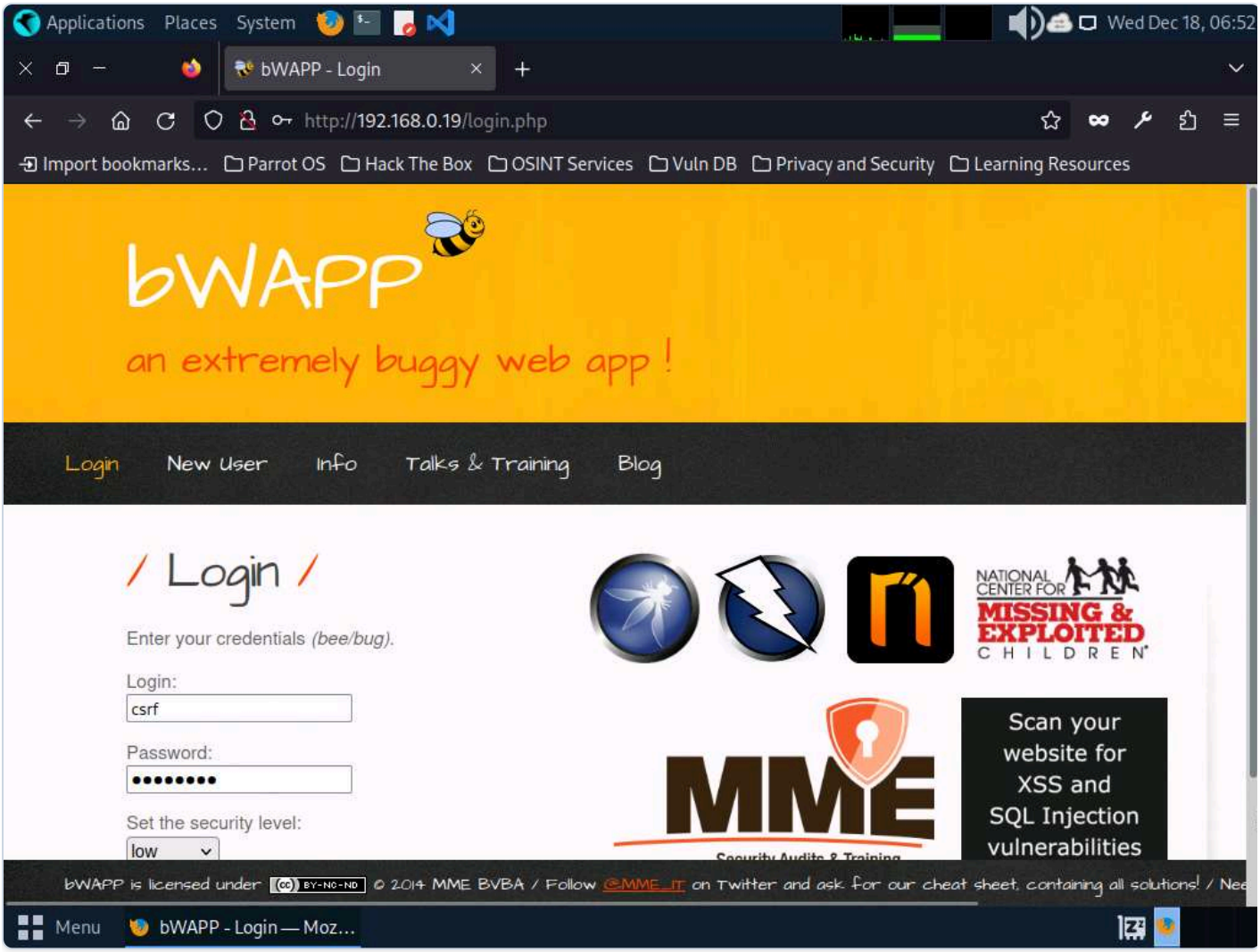
In this task, we create a new user account in bWAPP, access the fund transfer module, extract and craft a malicious HTML form payload, open the payload in a browser tab under the victim's authenticated session, and verify unauthorized deduction of funds from the default balance (**1000 EUR**).

Lab Tasks

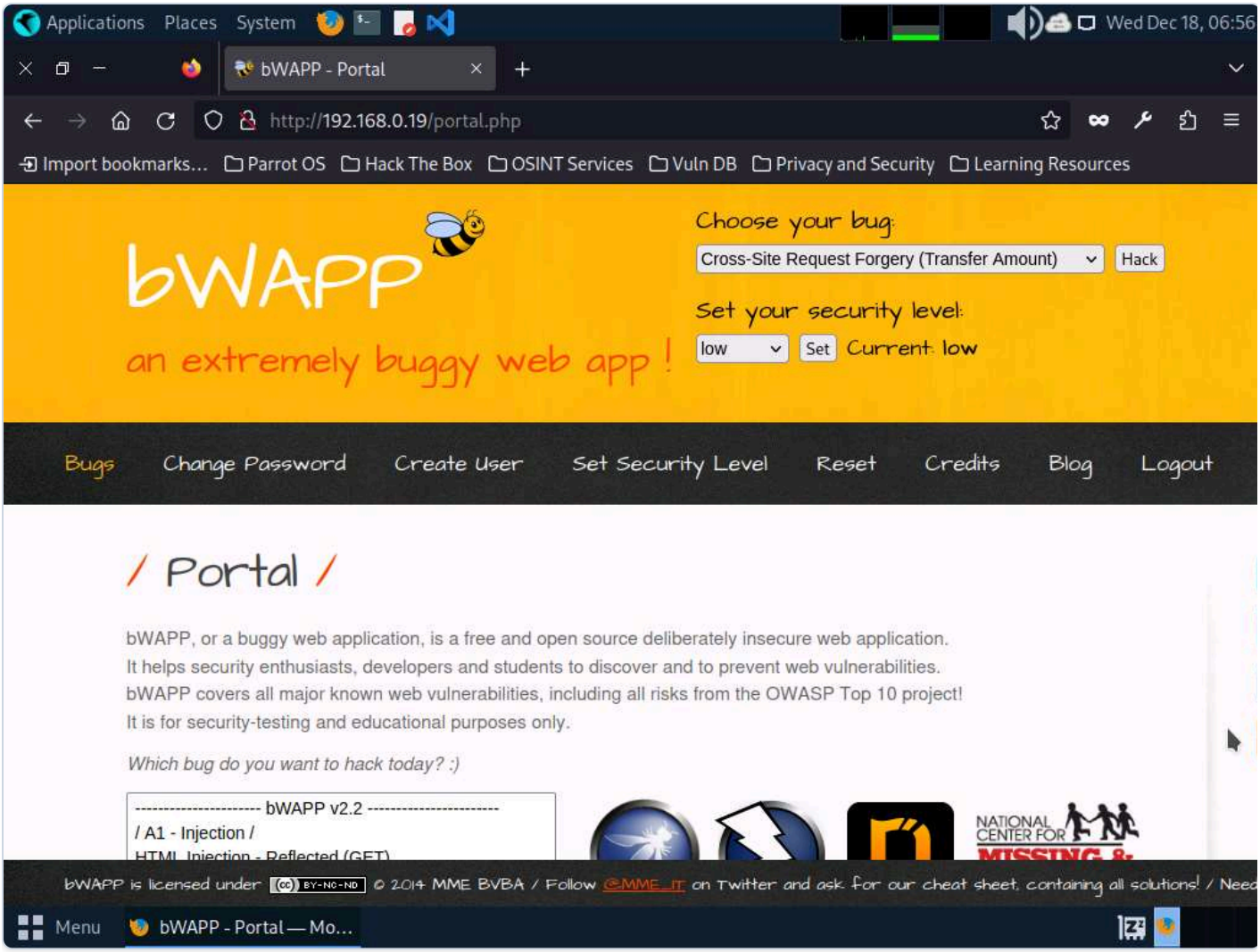
1. In the **Parrot Security** machine, launch Firefox, access bWAPP (`http://192.168.0.19`), and log in with **bee** / **bug**.
2. Click **Create user**, fill in the required user registration details, and click **Create**.



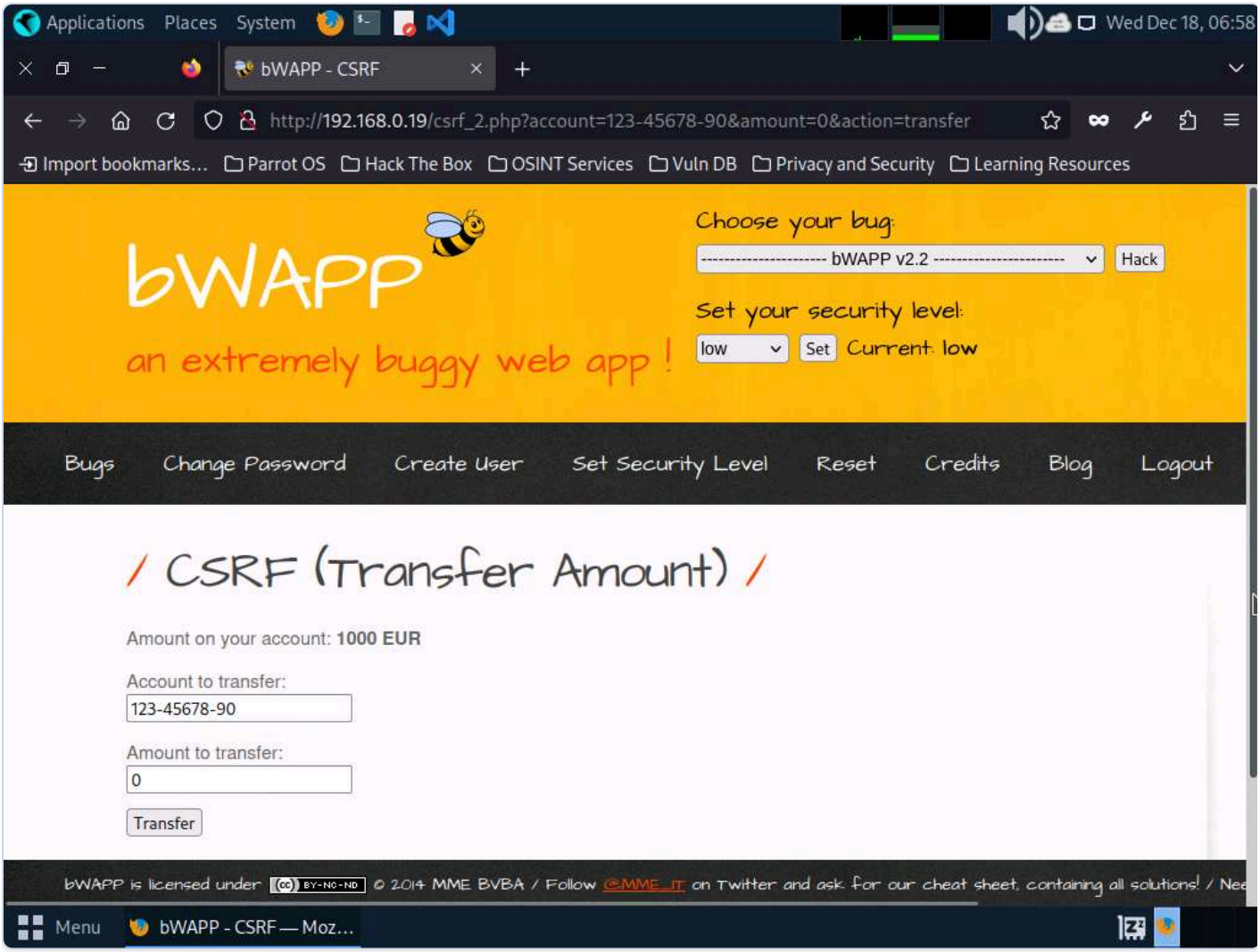
1. Log out of bWAPP, then log in using your newly created user credentials. Ensure the **Security Level** is set to **Low**. Note the default starting account balance: **1000 EUR**.



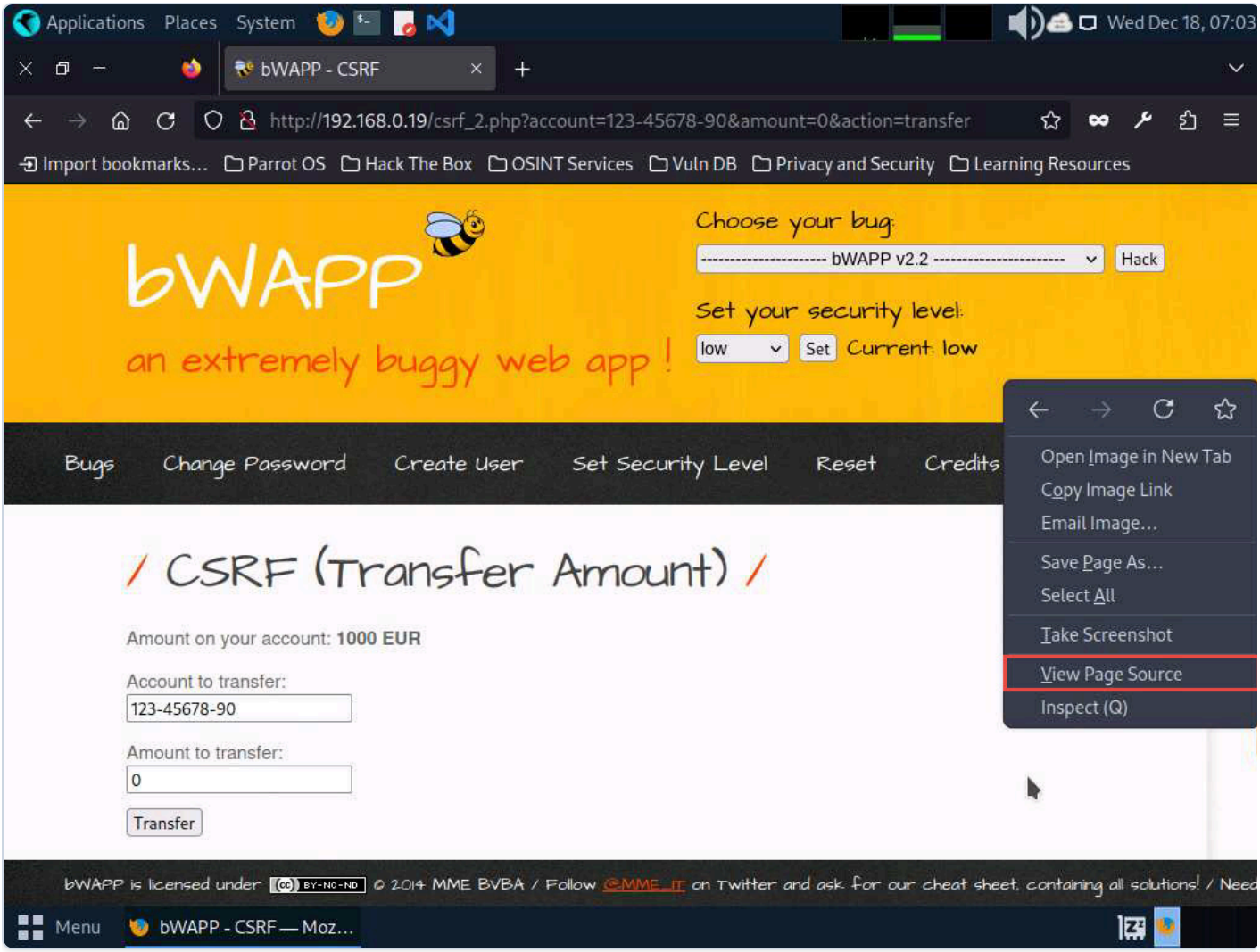
1. Select **Cross-Site Request Forgery (Transfer Amount)** from the **Choose your bug** drop-down list and click **Hack**.



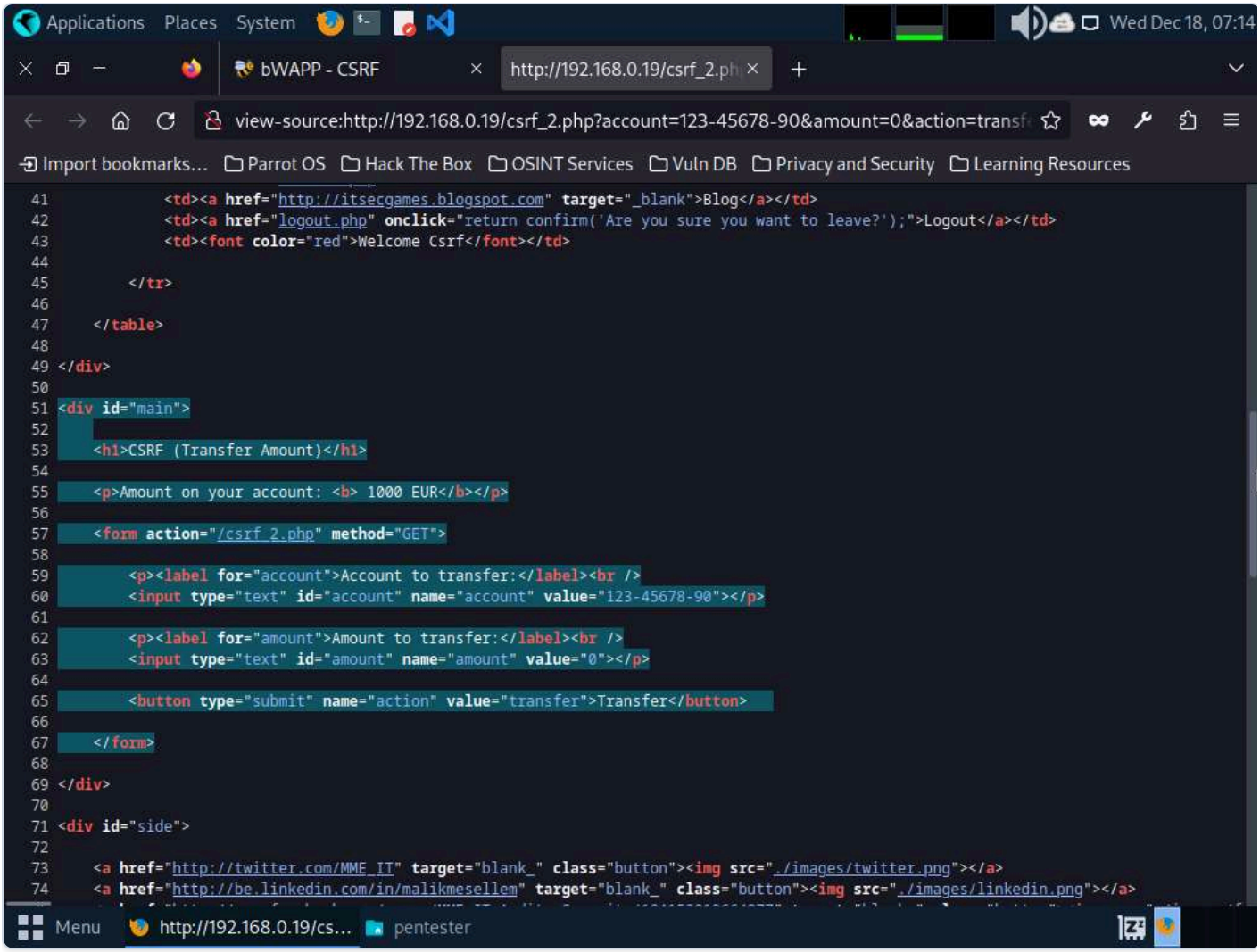
1. In the CSRF (Transfer Amount) interface, leave the default transfer values and click **Transfer**.



1. Inspect the resulting URL parameter structure:
   http://192.168.0.19/csrf_1.php?account=123456789&amount=100&action=transfer
2. Right-click on the web page and select **View Page Source**.

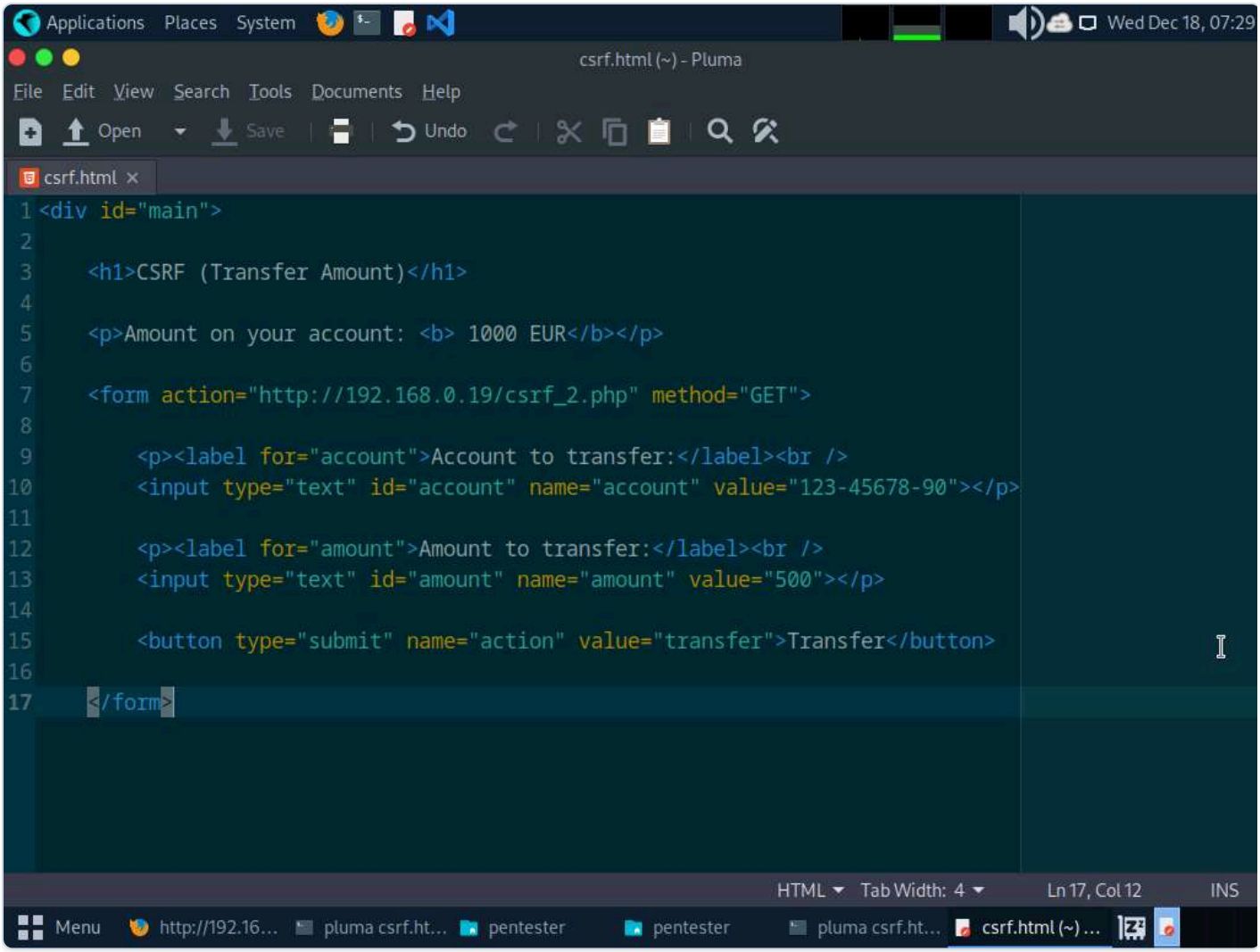


1. Locate the `<div id="main">` form section in the HTML source code. Copy the form structure into a local text editor to modify the destination account number and transfer amount.

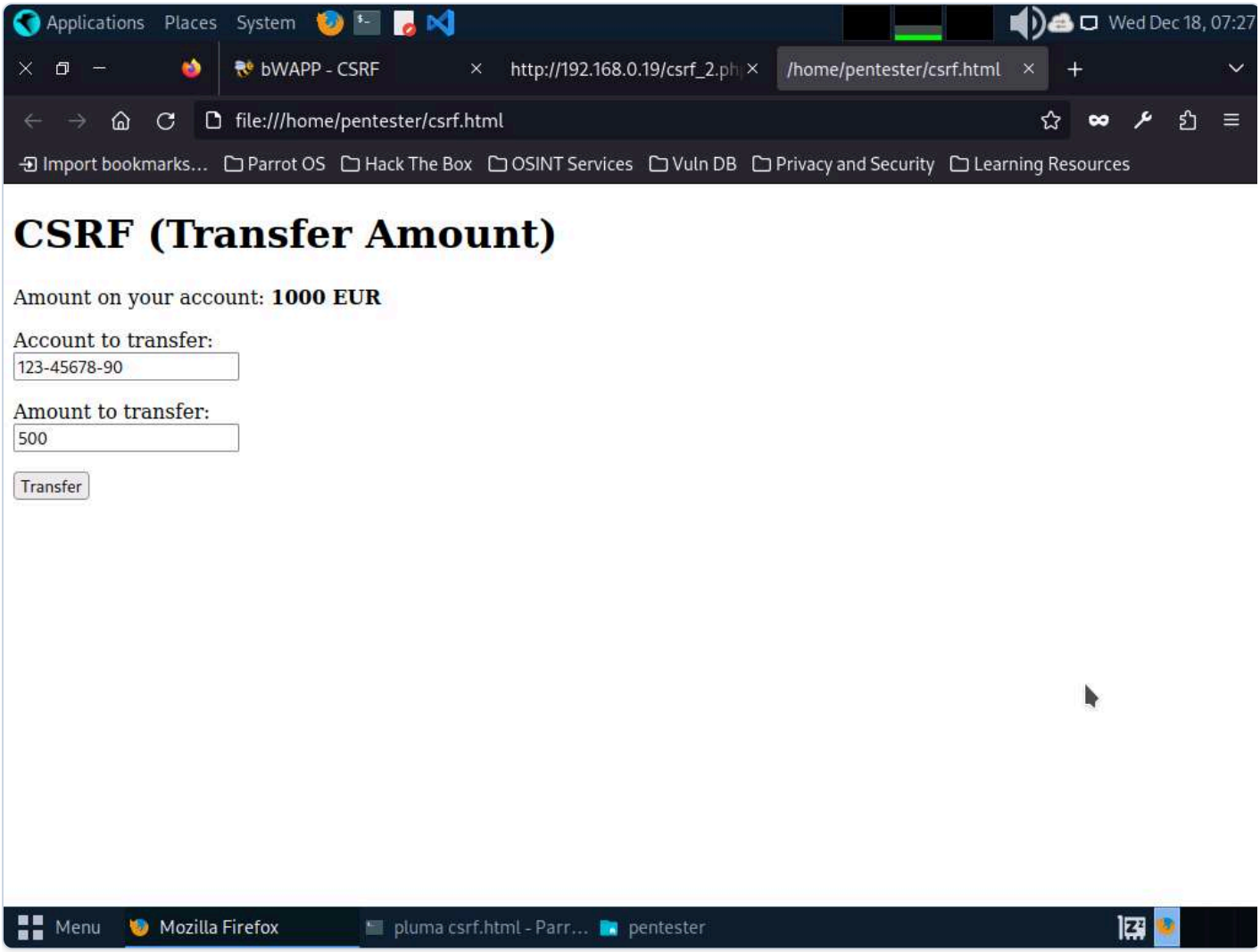


1. Craft a standalone malicious HTML exploit page (e.g., `csrf_exploit.html`) containing an auto-submitting form or button targeting the transfer endpoint:

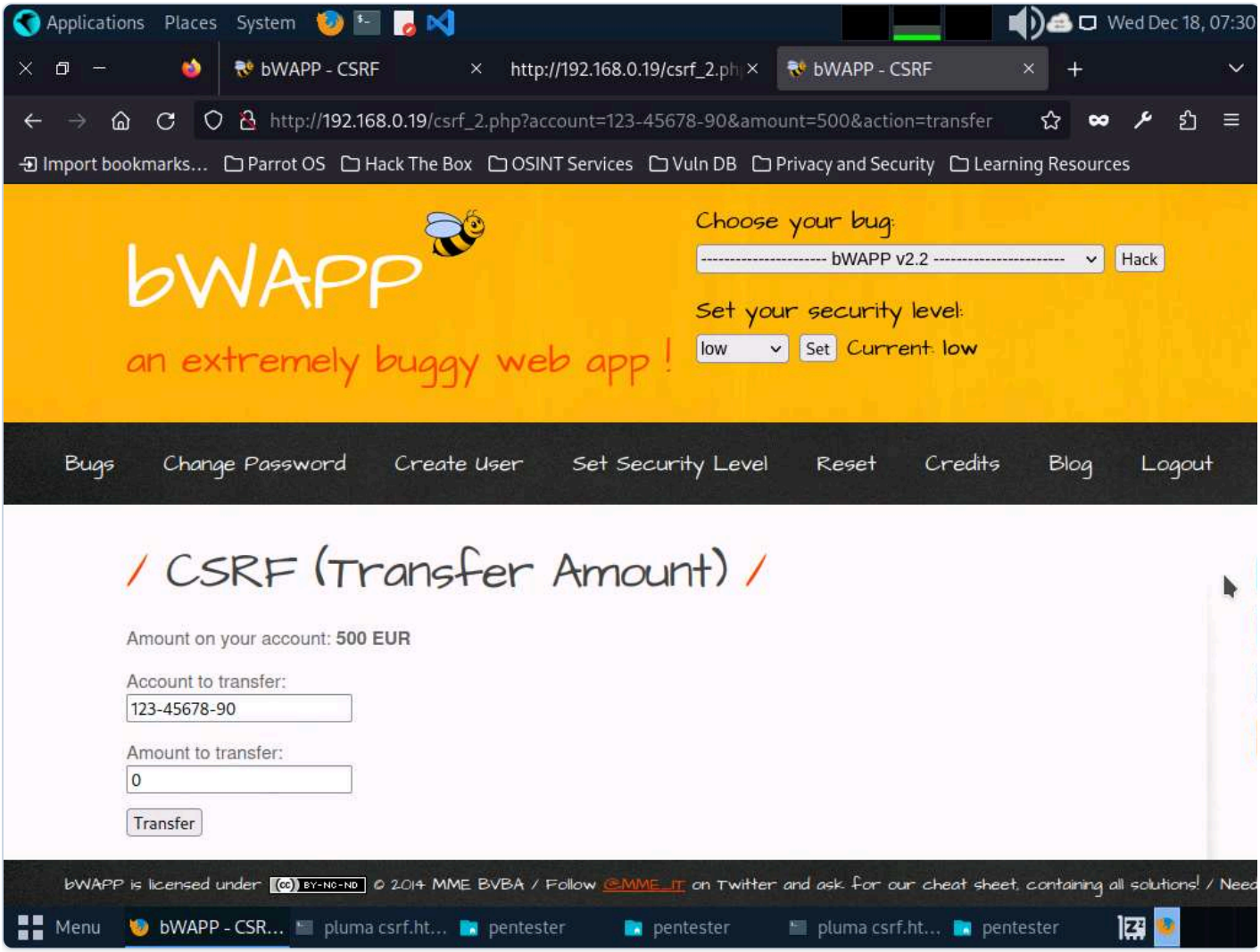
```
<form action="http://192.168.0.19/csrf_1.php" method="GET">
    <input type="hidden" name="account" value="987654321" />
    <input type="hidden" name="amount" value="500" />
    <input type="hidden" name="action" value="transfer" />
    <input type="submit" value="Transfer" />
</form>
```



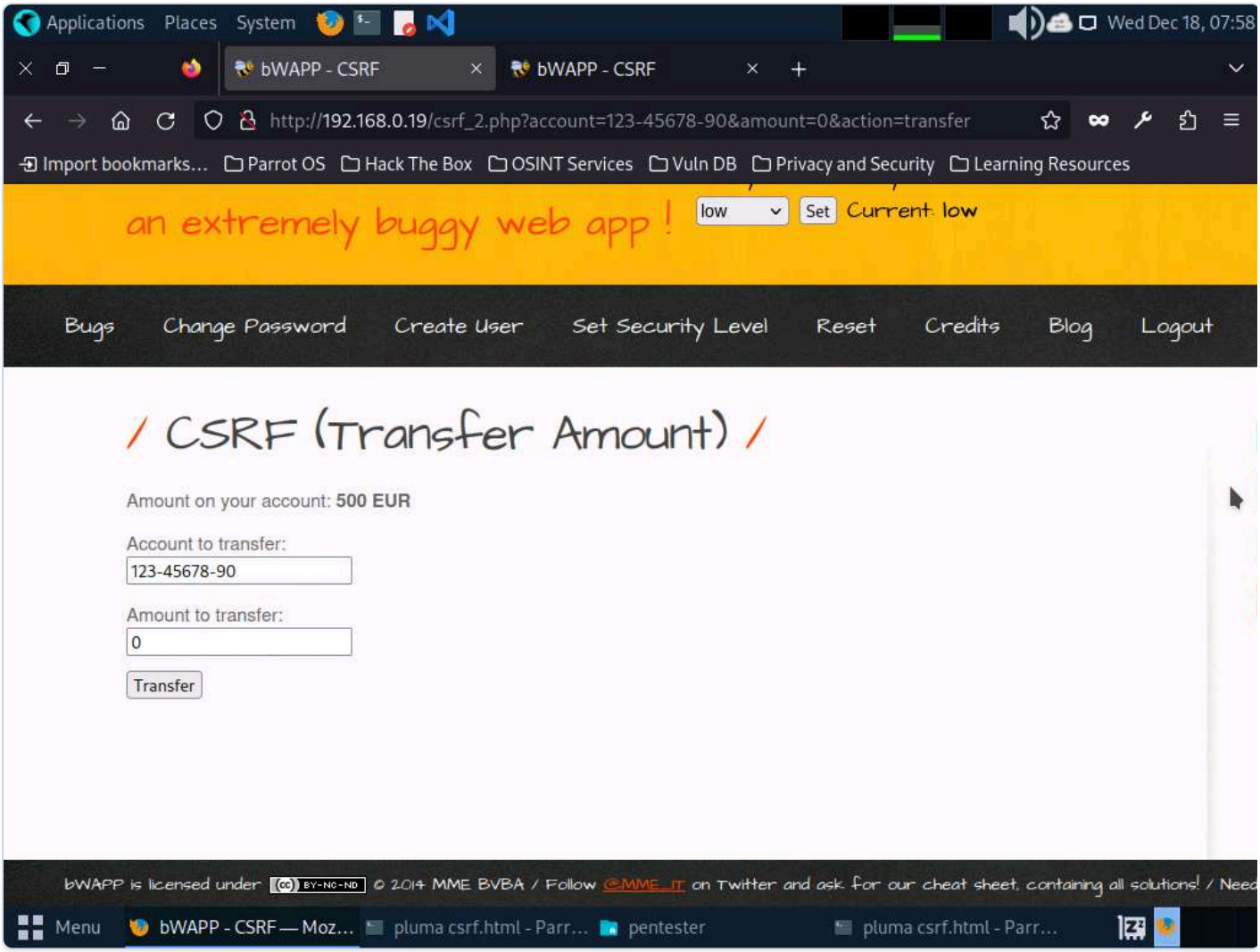
1. Save the exploit file locally and open it in a browser window while the victim user maintains an active session in bWAPP. Click **Transfer**.



1. Return to the victim's bWAPP tab and refresh the page. Observe that **500 EUR** has been deducted from the victim's initial balance (**1000 EUR**), transferring the funds to the attacker's designated account (`987654321`).



1. Optionally, embed the CSRF URL payload within stored fields (such as blog posts or images) to execute automatic background requests.



1. Close all open browser windows on Parrot Security. Leave bWAPP running on Ubuntu for subsequent exercises.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.15.1.1** On the Parrot Security machine, utilize bWAPP to simulate and analyze Cross-Site Request Forgery (CSRF) vulnerabilities by testing two distinct user roles within the application. Focus on the "Cross-Site Request Forgery (Transfer Amount)" vulnerability. Enter the Amount on the account available by default. [!SUCCESS] ✅ **Answer:** **1000 EUR**